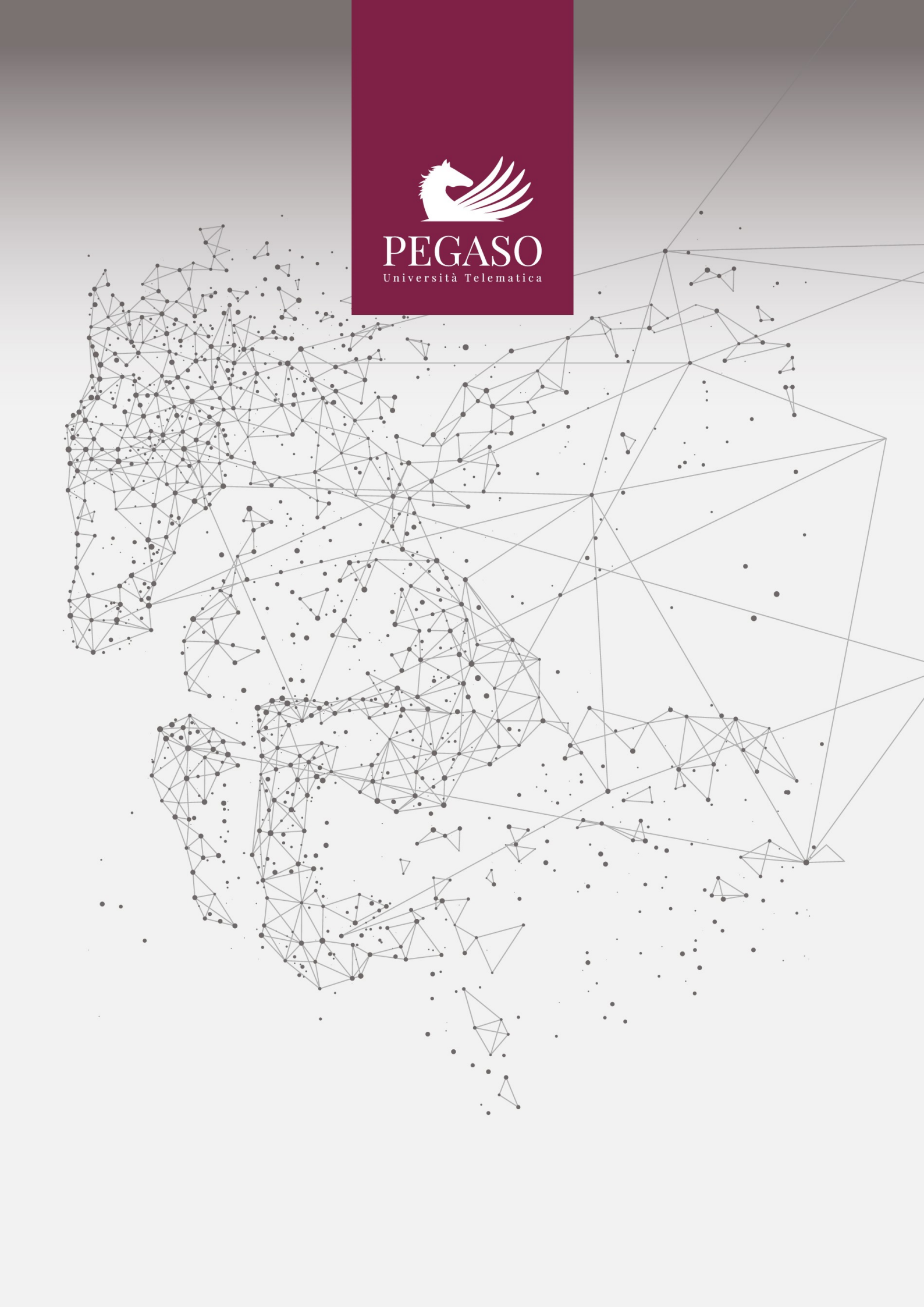

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. ENCAPSULATING SECURITY PAYLOAD (ESP)..... 3
2. COMBINAZIONI DI ASSOCIAZIONI DI SICUREZZA..... 6
3. GESTIONE DELLE CHIAVI..... 10
BIBLIOGRAFIA..... 14

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

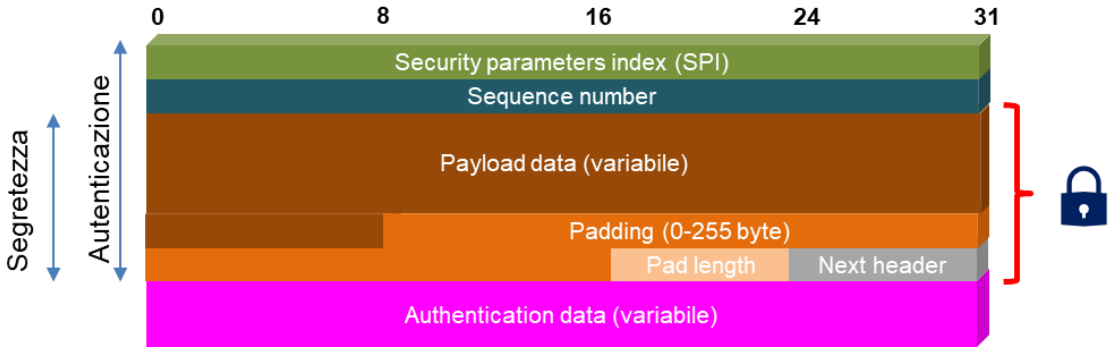
1. Encapsulating Security Payload (ESP)

IPSec fornisce i servizi di sicurezza a livello IP consentendo di selezionare i protocolli, di determinare gli algoritmi da utilizzare e di gestire le chiavi crittografiche. Come abbiamo già avuto modo di vedere, per garantire la sicurezza vengono impiegati due protocolli:

- un protocollo di autenticazione denominato *Authentication Header (AH)*
- un protocollo combinato di crittografia e autenticazione denominato *Encapsulated Security Payload (ESP)*

Consideriamo adesso il protocollo combinato di crittografia e autenticazione denominato *Encapsulated Security Payload (ESP)*.

ESP fornisce servizi di segretezza, fra cui la segretezza del contenuto del messaggio e una parziale segretezza del flusso del traffico. Opzionalmente ESP può fornire anche un servizio di autenticazione. Il formato di un pacchetto ESP è quello rappresentato in figura:



- I campi **SPI** e **Sequence number** sono uguali al caso AH
- Il campo **Payload Data** è il segmento di trasporto dei dati (modalità trasporto) o il pacchetto IP (modalità tunnel) protetto dalla crittografia
- **Padding** e **Pad length** servono per gestire il riempimento in relazione alla dimensione della word che è sempre di 32 bit, comunque li vediamo in dettaglio più avanti in questo paragrafo.

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- **Next header**: identifica il tipo di dati contenuti nel campo Payload Data
- **Authentication data**: contiene il valore Integrity Check Value generato come in AH e calcolato sul pacchetto ESP senza, ovviamente, il campo Authentication data

I campi *Payload Data*, *Padding*, *Pad Length* e *Next Header* sono crittografati dal servizio ESP (vedi in figura la parte individuata con l'icona del lucchetto). Se la crittografia necessita di un vettore di inizializzazione (IV), questo viene posto esplicitamente all'inizio del campo Payload Data e non viene cifrato. Gli algoritmi usati possono essere: Triple DES, IDEA ecc.

Anche ESP come AH supporta l'uso di un codice MAC con una lunghezza standard di 96 bit.

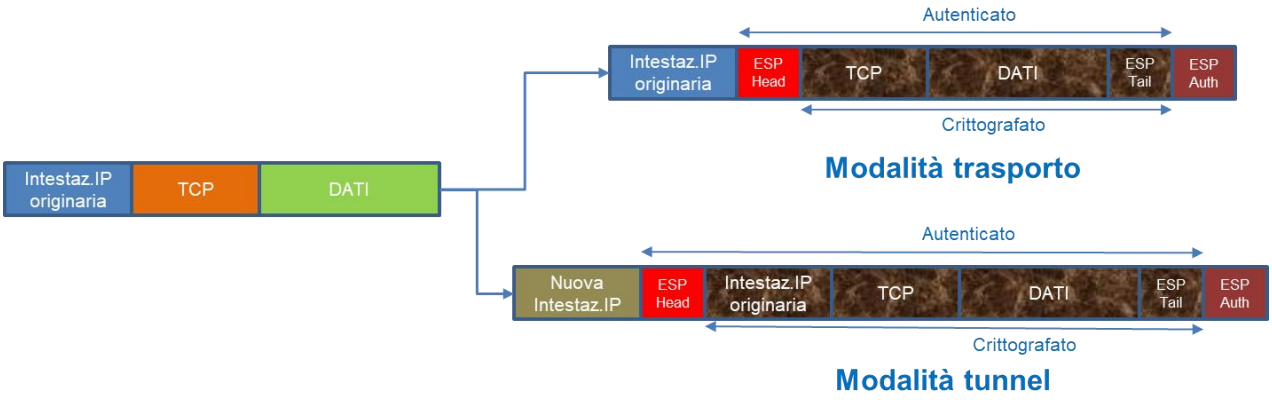
Vediamo adesso, come prima annunciato, il campo **Padding**; esso svolge varie funzioni:

- consente di espandere il testo in chiaro in modo da renderlo adatto con le esigenze di lunghezza definita per l'algoritmo di cifratura
- soddisfa il formato ESP che richiede che i campi *Pad Length* e *Next Header* siano allineati a destra all'interno di una word di 32 bit
- può essere usato per offrire un servizio di segretezza parziale del flusso del traffico inserendo dei bit di riempimento per nascondere l'effettiva lunghezza del payload.

Nel protocollo ESP (per esempio nel caso IPv4) il pacchetto IP viene così modificato nella modalità *trasporto* e *tunnel* (vedi figura). Nel caso di modalità trasporto l'intestazione ESP viene inserita nel pacchetto IP immediatamente prima dell'intestazione del livello di trasporto (e.g. TCP) e dopo il pacchetto IP viene aggiunta una coda ESP eventualmente seguita dal campo ESP di Authentication Data se è richiesta anche l'autenticazione. L'intero segmento del livello di trasporto insieme alla coda ESP vengono cifrati; l'autenticazione copre tutto il testo cifrato più l'intestazione ESP (vedi figura, ramo superiore).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Nel caso di modalità tunnel invece l'intestazione ESP precede il pacchetto IP e vengono crittografati l'intero pacchetto IP più la coda ESP. In questo modo si riesce a sventare attacchi ad analisi del traffico. L'autenticazione copre di nuovo tutto il testo cifrato più l'intestazione ESP (vedi figura ramo inferiore).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Combinazioni di associazioni di sicurezza

Una singola associazione di sicurezza può specificare il protocollo AH o ESP ma non entrambi. Talvolta però un determinato flusso di traffico può avere esigenze più complesse e richiedere:

- entrambi i servizi
- servizi fra gli host che sono diversi da quelli richiesti fra i gateway

Occorre in questo caso impiegare più associazioni di sicurezza ovvero si crea una *combinazione di SA*.

Le associazioni di sicurezza all'interno di una combinazione possono terminare negli stessi o in differenti punti di destinazione

Le SA si possono combinare sostanzialmente in due modi:

- *Adiacenza di trasporto*: consiste nell'applicare allo stesso pacchetto IP più protocolli di sicurezza senza utilizzare la modalità tunnel
- *Tunnel iterato*: consiste nell'applicare più protocolli di sicurezza tramite la modalità tunnel
    - ogni tunnel può avere diversa origine o destinazione

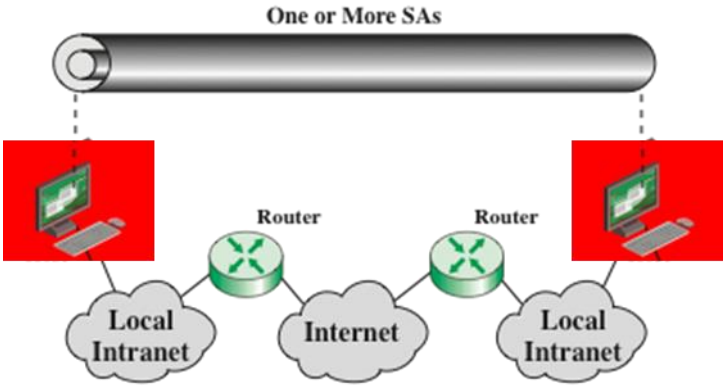
Vediamo adesso alcuni esempi di combinazioni di associazioni di sicurezza. Nelle seguenti figure si utilizzerà la seguente simbologia:

-  implementazione di IPSec
-  non implementazione di IPSec

PEGASO
Università Telematica

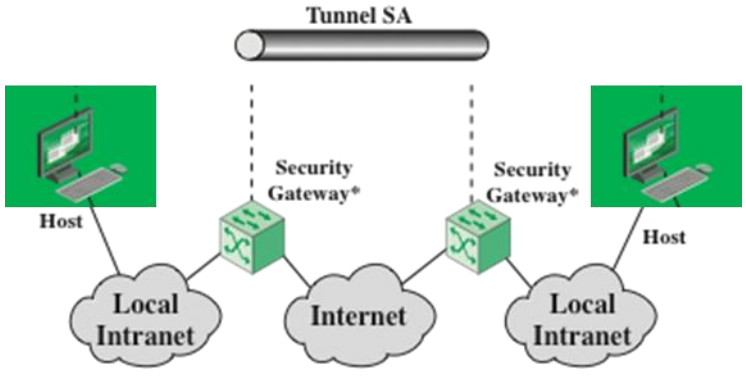
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Combinazione fra utenti terminali che implementano IPSec



In questo caso la sicurezza viene fornita dai sistemi terminali che implementano IPSec; può essere realizzato tramite una o più associazioni di sicurezza.

Combinazione fra gateway che implementano IPSec (non gli host)

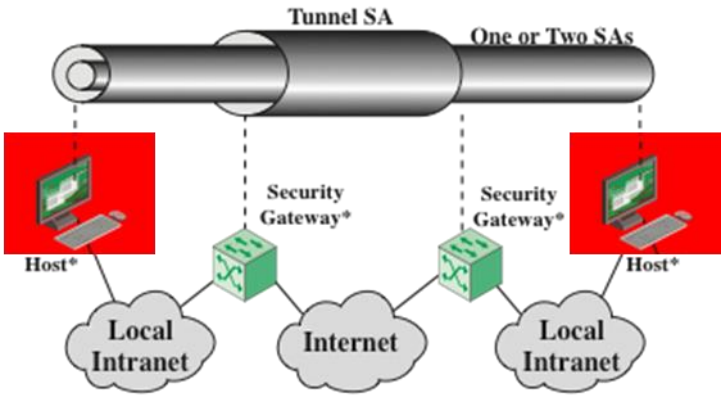


In questo caso la sicurezza viene fornita solo fra gateway (router, firewall) mentre nessun host implementa IPSec. Adesso è necessaria un'unica associazione di sicurezza a tunnel (AH, ESP o ESP con opzione di autenticazione).

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Combinazione fra gateway che implementano IPSec con sicurezza end-to-end

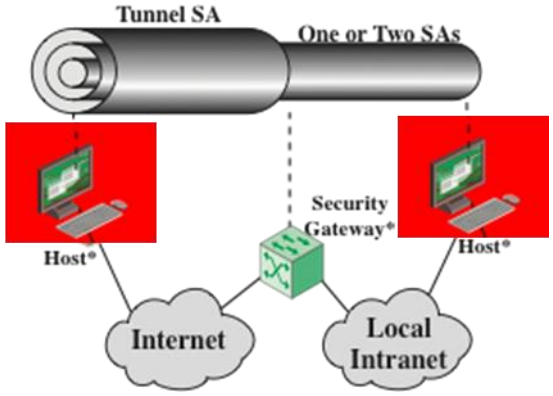


Praticamente, in questo caso, si estende la situazione precedente aggiungendo la sicurezza end-to-end tramite una o più associazioni di sicurezza utili per specifiche applicazioni o per determinati utenti.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Combinazione per l'accesso di un host remoto ad un gateway aziendale per poi accedere ad un server interno



In questo caso si riesce a fornire il supporto per l'acceso di un host remoto da Internet verso il firewall di una rete aziendale (modalità tunnel) da cui poi accedere a qualche server o macchina specifica protetta da un altro firewall attraverso uno o due associazioni di sicurezza in maniera equivalente a quanto visto nel primo caso dei quattro proposti.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. Gestione delle chiavi

La gestione delle chiavi *(IKE- Internet Key Exchange)* in IPSec comporta la scelta e la distribuzione delle chiavi segrete. Il protocollo standard per la gestione delle chiavi è basato fondamentalmente a sua volta su due protocolli

- *Oakley Key Determination Protocol*: protocollo per lo scambio delle chiavi basato sull'algoritmo Diffie-Hellman ma con una sicurezza superiore
- *Internet Security Association and Key Management Protocol (ISAKMP)*: specifica un'architettura per la gestione delle chiavi e il supporto per la negoziazione delle associazioni di sicurezza

Oakley Key Determination Protocol è un miglioramento dell'algoritmo Diffie-Hellman per lo scambio di chiavi. Diffie-Hellman presenta due caratteristiche interessanti:

- le chiavi segrete vengono create solo quando è necessario
- lo scambio non richiede un'infrastruttura preesistente, eccetto un accordo globale sui parametri

Lo stesso scambio Diffie-Hellman presenta anche dei punti deboli:

- non fornisce informazioni sull'identità delle parti
- è soggetto all'attacco man-in-the-middle
- è computazionalmente pesante e quindi vulnerabile ad un attacco di *clogging* in cui un estraneo richiede un elevato numero di chiavi e la vittima impiega risorse in inutili calcoli esponenziali modulari

Oakley Key Determination Protocol migliora Diffie-Hellman praticamente inserendo:

- un meccanismo di cookie per evitare gli attacchi *clogging*

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- consente alle due parti di negoziare un *gruppo* che specifica i parametri globali da usare nello scambio delle chiavi
- utilizza dei nonce per difendersi dagli attacchi replay
- autentica lo scambio Diffie-Hellman per impedire l'attacco man-in-the-middle (tramite firme digitali, crittografia a chiave pubblica o a chiave simmetrica)

Internet Security Association and Key Management Protocol (ISAKMP) specifica le procedure e i formati dei pacchetti necessari per attivare, negoziare, modificare e cancellare le associazioni di sicurezza. Un messaggio ISAKMP è costituito da:

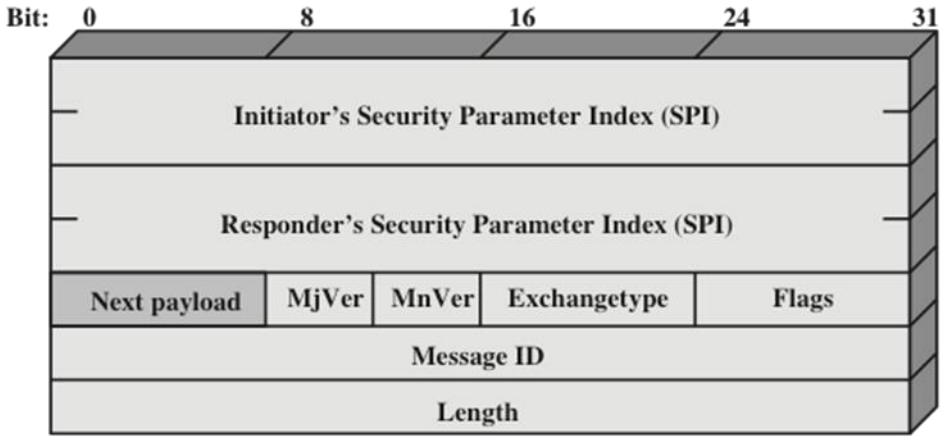
- un'intestazione ISAKMP
- uno o più payload ISAKMP di differenti tipologie che contengono a loro volta un'intestazione generica

L'intestazione ISAKMP è costituita dai seguenti campi (vedi figura seguente):

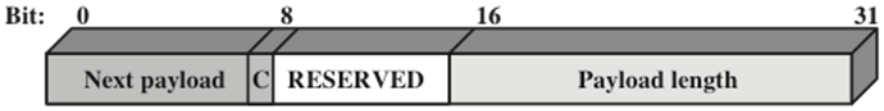
- *Initiator cookie* (64 bit)
- *Responder cookie* (64 bit)
- *Next payload*: indica il tipo del primo payload
- *Major/Minor version:* versione usata
- *Exchange Type*: ne esistono 5 tipi
- *Flags*: indica le opzioni per lo scambio
- *Message ID*: codice univoco
- *Length*: lunghezza totale del messaggio (intestazione e payload)

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



I vari **tipi di payload ISAKMP** sono a loro volta sempre preceduti da un'intestazione generica:



- *Next payload*: vale 0 se questo è l'ultimo payload, altrimenti il suo valore indica il tipo del successivo payload (vedi tabella in figura)
    - Il nono è un bit critico che serve per indicare al destinatario se il mittente vuole che il payload sia scartato o meno sotto certe condizioni.
- *Payload length*: indica la lunghezza in byte del payload compresa la stessa intestazione generica
- Ogni payload è caratterizzato da dei parametri (vedi tabella in figura)

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Type	Parameters
Security Association	Proposals
Key Exchange	DH Group #, Key Exchange Data
Identification	ID Type, ID Data
Certificate	Cert Encoding, Certificate Data
Certificate Request	Cert Encoding, Certification Authority
Authentication	Auth Method, Authentication Data
Nonce	Nonce Data
Notify	Protocol-ID, SPI Size, Notify Message Type, SPI, Notification Data
Delete	Protocol-ID, SPI Size, # of SPIs, SPI (one or more)
Vendor ID	Vendor ID
Traffic Selector	Number of TSs, Traffic Selectors
Encrypted	IV, Encrypted IKE payloads, Padding, Pad Length, ICV
Configuration	CFG Type, Configuration Attributes
Extensible Authentication Protocol	EAP Message

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: Capitoli 16.
- "Cryptography and Network Security", 7/ed, William Stallings, Pearson, Capitolo 20.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).